Caso de estudio: Riesgos y ataques cibernéticos en una empresa mediana

TechNova S.A.

1. Resumen del caso

TechNova S.A. es una empresa de servicios tecnológicos y consultoría con 250 empleados. Su infraestructura combina servidores internos y en la nube (Azure), ERP y CRM en línea, correo corporativo, Teams y SharePoint. En los últimos dos años creció rápido, pero no hizo auditorías de seguridad ni capacitó a su personal.

En marzo de 2024 sufrió un ataque de **ransomware**. Todo empezó con un correo de phishing dirigido a contabilidad, que parecía venir de un proveedor habitual e incluía un PDF que ejecutó un script malicioso. El ataque dejó estas consecuencias:

- Cifrado del 80 % de los archivos del servidor principal.
- Pérdida temporal de acceso a las bases de datos de clientes.
- Exigencia de un rescate de 15 000 USD en criptomonedas.
- Cinco días de operaciones paralizadas.
- Pérdida estimada de 75 000 USD entre costos directos e indirectos.

2. Identificación del ataque

Se trata de un ataque de **ransomware** con ingeniería social como vector de entrada (phishing). La amenaza es un actor externo con motivación económica, y los activos afectados fueron el servidor principal, las bases de datos de clientes, el ERP y CRM, y la continuidad de las operaciones.

Tríada de la CIA

Principio	Cómo se vio afectado
Disponibilidad	Es el más afectado: los archivos quedaron cifrados, las bases de datos inaccesibles y la empresa estuvo cinco días sin operar
Integridad	Los archivos cifrados dejaron de ser utilizables, y mientras no se verifiquen no podemos asegurar que los datos no hayan sido alterados
Confidencialidad	Está en riesgo porque el malware se conectó a un servidor remoto. El caso no confirma robo de datos, así que habría que investigarlo, ya que algunos ransomware roban la información antes de cifrarla

Análisis con la Cadena de Eliminación Cibernética (Cyber Kill Chain)

N.°	Paso	Qué pasó en TechNova
1	**Reconocimiento**	Suponemos que el atacante investigó a la empresa y eligió a contabilidad y a un proveedor habitual como objetivo, porque el correo era muy creíble. El caso no lo menciona de forma explícita

N.°	Paso	Qué pasó en TechNova
2	**Armamentización**	Preparó un PDF con un script malicioso que ejecuta el ransomware
3	**Entrega**	Envió un correo de phishing que aparentaba ser de un proveedor conocido
4	**Explotación**	El empleado abrió el archivo y se ejecutó el script
5	**Instalación**	El malware se instaló y se propagó. La falta de segmentación de red le permitió llegar al servidor principal
6	**Comando y Control (CnC)**	Se conectó con un servidor remoto del atacante
7	**Acciones sobre Objetivos**	Cifró el 80 % de los archivos y exigió el rescate

La cadena se pudo cortar en tres puntos: en la **entrega**, con un filtro de correo y de adjuntos; en la **explotación**, con usuarios capacitados, macros desactivadas y antivirus actualizado; y en la **instalación**, con segmentación de red. Mientras más temprano se corte, menor es el daño.

Según el marco MITRE ATT&CK, el ataque corresponde a las técnicas de phishing (T1566), ejecución por el usuario (T1204) y datos cifrados para causar impacto (T1486).

3. Causas raíz

Tipo	Causa
Humana	El empleado abrió el archivo sin verificar al remitente y no tenía formación en seguridad digital
Técnica	Antivirus sin actualizar, red sin segmentar, copias de seguridad poco seguras, contraseñas débiles y ausencia de autenticación multifactor
Organizacional	Crecimiento acelerado sin auditorías, sin capacitación, sin plan de respuesta a incidentes y sin políticas de seguridad claras

Concluimos que el ataque no fue únicamente un fallo técnico: combinó un error humano con la falta de controles básicos y de gobernanza.

4. Evaluación de riesgos

Matriz de riesgos (análisis cualitativo)

El nivel de riesgo se obtiene combinando la probabilidad con el impacto. Los valores iniciales son los del caso. Para la última columna hacemos una **estimación** del nivel residual, es decir, el riesgo que queda después de aplicar las medidas correctivas, considerando cuánto cubre cada una de ellas.

Riesgo	Probabilidad	Impacto	Nivel inicial	Nivel residual (estimado)	Justificación
Phishing y malware	Alta	Alto	Crítico	Medio	La capacitación y el EDR ayudan, pero falta un filtro de correo
Falta de capacitación	Alta	Medio	Alto	Bajo / Medio	La capacitación es obligatoria, pero debe repetirse
Pérdida de datos	Media	Alto	Alto	Medio	Solo existen copias parciales
Acceso no autorizado	Alta	Alto	Crítico	Medio	El MFA ayuda, pero falta una política de contraseñas
Reputacional	Media	Alto	Alto	Medio / Alto	Depende de cómo se comunique el incidente

Los dos riesgos críticos, phishing y acceso no autorizado, deben atenderse primero, y después los de nivel alto.

Análisis cuantitativo

Del caso tomamos la **expectativa de pérdida única (SLE)**, que es de **75 000 USD**. Como el caso no da la frecuencia del ataque, **supongamos que ocurre una vez cada dos años**, es decir, que la **tasa de ocurrencia anual (ARO) es de 0,5**. Con ese supuesto:

- **ALE** (expectativa de pérdida anual) = SLE × ARO = 75 000 × 0,5 = **37 500 USD al año**.

Si los controles (MFA, EDR, capacitación y copias de seguridad) cuestan menos de esa cifra al año y reducen de forma importante la probabilidad del ataque, la inversión se justifica.

Pagar el rescate de 15 000 USD tampoco es una buena opción. No garantiza recuperar los datos, financia al atacante y no corrige la causa del problema. Además, la pérdida total incluye costos que el pago no evita, como los cinco días sin operar.

Respuesta al riesgo

Respuesta	Aplicación en TechNova
Reducción	Es la principal: MFA, EDR, capacitación, segmentación, parches y copias de seguridad
Transferencia	Contratar un seguro de ciberriesgo y apoyarse en los acuerdos de nivel de servicio de Azure
Aceptación	Aceptar solo el riesgo residual bajo, con revisiones periódicas

Respuesta	Aplicación en TechNova
Evasión	Deshabilitar funciones de alto riesgo, como las macros de los documentos que llegan por correo

5. Evaluación de las medidas implementadas

Medida	Tipo de control	Riesgo que reduce	Observación
Restauración con copias de seguridad parciales	De recuperación	Pérdida de datos	Es insuficiente: se necesitan copias completas, fuera de línea y probadas
MFA	Preventivo (técnico)	Acceso no autorizado	Es una buena medida, pero falta una política de contraseñas
Auditoría externa	De detección (administrativo)	Todos	Debe repetirse periódicamente
Capacitación en ciberhigiene	Preventivo (administrativo)	Phishing y falta de capacitación	Conviene reforzarla con simulacros de phishing
EDR	De detección y correctivo (técnico)	Malware y ransomware	Debe monitorearse de forma permanente
Plan de respuesta a incidentes	Correctivo (administrativo)	Impacto de futuros incidentes	Debe practicarse con ejercicios de mesa

Las medidas van en la dirección correcta, pero no cubren todo. Los controles que siguen pendientes se incluyen en las recomendaciones.

6. Plan de respuesta a incidentes (ciclo de vida de NIST)

Fase	Acciones para TechNova
1. Preparación	Crear el CSIRT con representantes de TI, Legal, Recursos Humanos, Relaciones Públicas, Gerencia y Continuidad del negocio. Definir roles, herramientas, inventario de activos, copias de seguridad probadas y contactos externos
2. Detección y análisis	Detectar con el EDR y un SIEM, confirmar que se trata de un incidente real, determinar su alcance, clasificarlo, priorizarlo y notificar a las partes interesadas
3. Contención,	Aislar de inmediato los equipos infectados y desconectar el servidor

Fase	Acciones para TechNova
erradicación y recuperación	afectado. Luego eliminar el malware, identificar todos los hosts que necesitan corrección, cambiar credenciales y parchear. Por último, restaurar desde copias limpias y verificar antes de reconectar
4. Actividades posteriores	Revisar qué falló, aplicar las lecciones aprendidas y actualizar controles y políticas

Manejo de la evidencia

Hay que conservar los **indicadores de compromiso** (el correo, el PDF, los registros y la conexión al servidor remoto) para el análisis y la atribución. Se debe seguir el **orden de volatilidad** (RFC 3227), recolectando primero los datos que se pierden más rápido, como la memoria, y mantener la **cadena de custodia**. El proceso forense comprende recolección, examen, análisis y presentación de informes.

Comunicación

El equipo legal debe revisar si existe obligación de notificar a los clientes y a las autoridades, dado que se vieron afectadas las bases de datos de clientes. Un mensaje claro a los clientes ayuda a limitar el daño reputacional.

7. Recomendaciones

Plazo	Acciones
Corto plazo (0 a 3 meses)	Actualizar el antivirus y los parches, activar un filtro de correo, desactivar las macros, hacer copias de seguridad completas y fuera de línea (con pruebas de restauración), establecer una política de contraseñas, hacer simulacros de phishing y probar el plan de respuesta con un ejercicio de mesa
Mediano plazo (3 a 12 meses)	Segmentar la red (VLAN y DMZ), implementar un SIEM con registros centralizados, aplicar el principio de privilegio mínimo, elaborar un plan de continuidad del negocio y de recuperación ante desastres (con BIA, RTO y RPO definidos) y contratar un seguro de ciberriesgo
Largo plazo (más de 12 meses)	Adoptar el modelo Zero Trust, realizar auditorías y pruebas de penetración periódicas, establecer una gobernanza de ciberseguridad con políticas formales (por ejemplo, alineada con ISO 27000) e incorporar inteligencia de amenazas

8. Conclusión

El caso de TechNova muestra que crecer rápido sin seguridad acumula riesgos: la protección debe crecer al mismo ritmo que la infraestructura. Las medidas implementadas reducen el riesgo, pero no lo eliminan, por lo que hay que cerrar las brechas pendientes y mantener una revisión continua. Con copias de seguridad sólidas y un plan de respuesta probado, el incidente

habría costado mucho menos que 75 000 USD y no habría paralizado la operación durante cinco días.